

UNIVERSITÀ DEGLI STUDI DI SALERNO

Dipartimento di Ingegneria dell'Informazione
ed Elettrica e Matematica Applicata

Corso di Laurea in Ingegneria Informatica



Algoritmi e Protocolli per la Sicurezza

Project Work – Gruppo 20

Nome	Cognome	Matricola
Chiara	Amoroso	IE22700309
Antonio	Esposito	IE22700003

Anno Accademico 2025/2026

Indice

1	WP 1: Modello del Sistema	2
1.1	Funzionalità del Sistema e Scenario Applicativo	2
1.2	Identificazione degli Attori	3
1.3	Modello di Minaccia e Avversari	4
1.4	Proprietà di Sicurezza e Resilienza	8
1.5	Completezza	10
1.6	Compromessi Progettuali e Assunzioni di Fiducia	11
2	WP 2: Soluzione	13
2.1	Strumenti crittografici utilizzati	13
2.2	Sintesi delle chiavi	14
2.3	Fase 0 — Configurazione del sistema	15
2.4	Fase 1 — Autenticazione ed emissione dell'autorizzazione pseudonima . . .	16
2.5	Fase 2 — Preparazione e invio del voto	17
2.6	Fase 3 — Raccolta e validazione sul Bulletin Board	18
2.7	Fase 4 — Sostituzione del voto	19
2.8	Fase 5 — Chiusura delle urne e scrutinio	20
2.9	Fase 6 — Verifica	22
2.10	Efficienza attesa e scalabilità	24
2.11	Estensioni possibili non incluse nel prototipo base	24
3	WP3: Analisi della Sicurezza	25
3.1	Obiettivo e metodo dell'analisi	25
3.2	Analisi rispetto alle proprietà del WP1	26
3.3	Analisi delle minacce e delle contromisure	29
3.4	Limiti residui e compromessi non completamente risolti	31
3.5	Considerazioni per WP4	32

WP 1: Modello del Sistema

Funzionalità del Sistema e Scenario Applicativo

Il sistema ha l'obiettivo di digitalizzare in modo sicuro l'elezione per il rinnovo del Consiglio Direttivo Provinciale dell'Ordine degli Ingegneri. Il protocollo adotta un modello elettorale a **lista chiusa**, nel quale ciascun avente diritto può esprimere una sola preferenza verso una delle liste candidate ammesse.

La scelta della lista chiusa è motivata da esigenze di semplicità, efficienza e verificabilità. Rispetto a un'elezione con preferenza nominale, il dominio dei voti è ridotto a un insieme piccolo e predeterminato di codici, ad esempio {001, 002, 003}. Questo semplifica il formato della scheda elettronica, la validazione dei voti, la cifratura e lo scrutinio finale. Tale scelta consente inoltre di concentrare l'analisi sugli aspetti principali richiesti dal progetto: autenticazione degli elettori, pseudoanonimato, integrità del registro, verificabilità individuale e controllo pubblico del risultato.

Il sistema deve permettere agli ingegneri iscritti all'Albo e aventi diritto, di votare da remoto mediante un'interfaccia digitale. Al termine della votazione, la lista vincente viene determinata in base ai voti validamente registrati e i seggi sono assegnati secondo l'ordine di presentazione della lista.

Il ciclo di vita ideale dell'elezione si articola nelle seguenti fasi logiche.

Fase di configurazione

L'autorità competente pubblica l'elenco ufficiale delle liste ammesse e associa a ciascuna lista un codice identificativo univoco. Vengono inoltre definiti i parametri pubblici dell'elezione, il periodo di apertura e chiusura delle urne, gli attori coinvolti e le informazioni necessarie per consentire agli elettori di partecipare e agli osservatori di controllare il processo. L'elenco nominativo degli aventi diritto rimane nel dominio riservato della Registration Authority e non viene pubblicato sul Bulletin Board. Nella versione base del sistema vengono resi pubblici soltanto dati aggregati, come il numero totale degli aventi diritto.

Fase di autenticazione

L'elettore accede al sistema tramite credenziali istituzionali presso la Registration Authority. La RA verifica che l'utente sia iscritto all'Albo e abbia diritto a partecipare all'elezione. Se l'elettore non ha ancora ricevuto un'autorizzazione per la stessa elezione, la RA può procedere alla sua emissione. In caso di accessi successivi, l'autenticazione può essere ripetuta, ma la RA non rilascia una seconda autorizzazione. L'autenticazione è nominativa solo presso la RA e non deve essere trasferita al Bulletin Board o alla Tallying Authority.

Fase di emissione e raccolta del voto

Dopo l'autenticazione, l'elettore ottiene un'autorizzazione pseudonima che gli consente di depositare una scheda senza includere direttamente la propria identità reale nel voto. L'elettore genera quindi una scheda elettronica protetta contenente il codice della lista scelta. La scheda viene inviata al Bulletin Board, che verifica la validità dell'autorizzazione e registra il voto nel registro pubblico.

Fase di eventuale sostituzione del voto

Prima della chiusura delle urne, il sistema può consentire all'elettore di sostituire la propria scheda con una nuova versione. Questa scelta mitiga alcuni scenari di coercizione o furto iniziale dell'autorizzazione, poiché una ricevuta ottenuta prima della chiusura non prova necessariamente quale voto sarà conteggiato alla fine. Ai fini dello scrutinio, per ciascun elettore pseudonimo viene considerata solo l'ultima versione valida registrata prima della chiusura.

Fase di scrutinio e verifica

Alla chiusura delle urne, l'autorità elettorale procede allo scrutinio dei soli voti validamente registrati. I voti non validi o malformati vengono separati e motivati. Sono quindi pubblicati il risultato finale, l'elenco delle schede finali conteggiate in forma pseudonima e le informazioni necessarie per controllare l'integrità del registro, l'unicità dei voti finali e la coerenza numerica dei totali.

La versione base del protocollo garantisce **verificabilità individuale** e **controllo pubblico del registro**. La verificabilità universale del tally è però **parziale**: il pubblico non dispone, nella versione base, di una prova autonoma della corretta decifratura di ogni singola scheda. La correttezza dello scrutinio richiede quindi una fiducia residua nella Tallying Authority e nei commissari incaricati dello scrutinio.

Identificazione degli Attori

Al fine di garantire la separazione dei compiti e ridurre la fiducia in un'unica entità centralizzata, il modello prevede sei attori logici, ciascuno con responsabilità distinte.

Attore	Ruolo	Obiettivi principali	Risorse principali
Elettore	Partecipante legittimo al voto.	Autenticarsi, esprimere il proprio voto in segreto e verificare che la scheda sia stata inclusa nel registro.	Credenziali istituzionali, dispositivo locale, autorizzazione pseudonima, informazioni necessarie alla verifica individuale.

Attore	Ruolo	Obiettivi principali	Risorse principali
Registration Authority (RA)	Sistema di autenticazione e validazione degli aventi diritto.	Verificare l'identità dell'elettore, controllare il diritto di voto e rilasciare al massimo una autorizzazione per elezione.	Database riservato degli iscritti, credenziali istituzionali, chiave o meccanismo per emettere autorizzazioni.
Tallying Authority (TA)	Autorità di scrutinio.	Determinare l'insieme delle schede finali valide, eseguire lo scrutinio dopo la chiusura e pubblicare il risultato.	Chiavi pubbliche dell'elezione, accesso controllato alla capacità di decifrare durante lo scrutinio.
Bulletin Board (BB)	Registro pubblico append-only.	Ricevere, verificare e pubblicare le schede registrate e gli eventi rilevanti dell'elezione.	Registro pubblico consultabile, meccanismi di integrità, ricevute di deposito.
Commissari elettorali	Soggetti incaricati di cooperare allo scrutinio.	Autorizzare o partecipare allo scrutinio dopo la chiusura delle urne, riducendo il potere di una singola entità.	Credenziali operative o quote necessarie ad abilitare lo scrutinio, secondo il meccanismo definito nel WP2.
Liste candidate / osservatori	Osservatori del processo elettorale.	Controllare in modo indipendente il registro pubblico, l'unicità delle schede finali e la coerenza del risultato dichiarato.	Accesso ai dati pubblici dell'elezione e agli strumenti di verifica.

Modello di Minaccia e Avversari

Si assume che gli avversari esterni siano computazionalmente limitati, cioè non siano in grado di rompere in tempo utile le primitive crittografiche adottate dal protocollo. Il modello considera sia avversari esterni, che possono osservare, ritrasmettere, modificare o iniettare messaggi, sia avversari interni, come RA, BB, TA o commissari elettorali curiosi o disonesti.

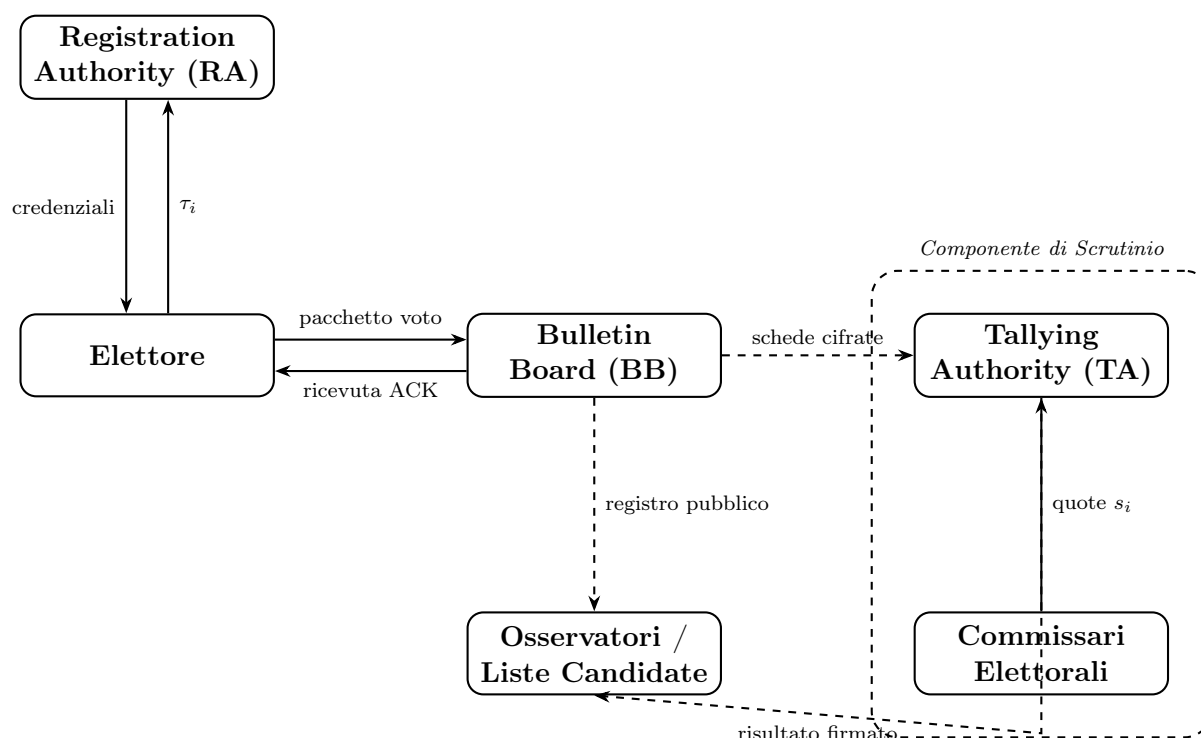


Figura 1: Schema degli attori e flussi principali del protocollo.

Attaccante passivo sulla rete

Tipologia: passivo.

Contesto e risorse: un avversario osserva i messaggi scambiati durante la votazione, inclusi i pacchetti contenenti le schede cifrate inviate al Bulletin Board. Può raccogliere ciphertext, timestamp e metadati di rete, ma non possiede le chiavi private delle autorità.

Obiettivo: dedurre la preferenza espressa da un elettore oppure correlare una scheda cifrata a un'identità reale.

Attacchi alla segretezza del voto cifrato

Tipologia: passivo o attivo, a seconda dello scenario.

Contesto e risorse: l'avversario può osservare solo ciphertext, conoscere alcune coppie voto-ciphertext ottenute a posteriori oppure generare voti scelti per studiare il comportamento della cifratura.

Obiettivo: sfruttare informazioni sui ciphertext per riconoscere voti uguali, costruire una tabella voto-ciphertext o dedurre la preferenza di altri elettori.

Elettore malizioso

Tipologia: attivo.

Contesto e risorse: un elettore legittimo può tentare di votare più volte, inviare schede malformate, riutilizzare vecchi pacchetti, produrre sostituzioni non valide o contestare il proprio voto dopo averlo depositato.

Obiettivo: ottenere il conteggio di più voti, disturbare la votazione o generare ambiguità nello scrutinio finale.

Contraffazione di autorizzazioni o pacchetti di voto

Tipologia: attivo.

Contesto e risorse: un avversario tenta di costruire un pacchetto di voto apparentemente valido senza aver ricevuto una autorizzazione dalla RA, oppure tenta di modificare un pacchetto legittimo.

Obiettivo: introdurre voti fraudolenti nel Bulletin Board o alterare voti già registrati.

Replay attack

Tipologia: attivo.

Contesto e risorse: un attaccante intercetta un pacchetto di voto valido già trasmesso da un elettore e lo ritrasmette invariato al BB.

Obiettivo: far conteggiare più volte lo stesso voto senza possedere nuove autorizzazioni valide.

Compromissione dello stato pseudonimo dell'elettore

Tipologia: attivo.

Contesto e risorse: un avversario compromette il dispositivo dell'elettore o il suo archivio locale e ottiene parte dello stato pseudonimo associato all'elezione, come l'autorizzazione τ_i , lo pseudonimo p_i , la chiave privata sk_i^{vote} , il segreto t_i , la versione corrente o le ricevute.

Obiettivo: impersonare l'elettore presso il BB, sostituire il voto prima della chiusura delle urne oppure impedire all'elettore di effettuare ulteriori sostituzioni.

RA curiosa o disonesta

Tipologia: passivo / insider.

Contesto e risorse: la Registration Authority autentica nominativamente l'elettore e rilascia l'autorizzazione pseudonima. Nella versione base può conoscere il collegamento tra identità reale e pseudonimo autorizzato.

Obiettivo: ricostruire l'associazione tra identità reale e voto, soprattutto in caso di collusione con BB o TA.

TA o commissari disonesti

Tipologia: attivo / insider.

Contesto e risorse: la Tallying Authority o alcuni commissari possono tentare di avviare lo scrutinio prima della chiusura, decifrare voti anticipatamente o alterare il conteggio.

Obiettivo: violare la segretezza del voto prima della chiusura o manipolare il risultato finale.

BB disonesto

Tipologia: attivo / insider.

Contesto e risorse: il gestore del Bulletin Board può tentare di omettere una scheda, cancellare o modificare entry già pubblicate, riordinare il registro oppure mostrare viste diverse a elettori e osservatori.

Obiettivo: sopprimere voti legittimi, favorire una lista o rendere ambiguo lo stato finale dell'elezione.

Attacchi alle funzioni hash e alla hash chain

Tipologia: attivo.

Contesto e risorse: un avversario tenta di trovare due entry diverse con lo stesso digest, oppure di sostituire una scheda già pubblicata con un'altra che mantenga invariati gli identificativi.

Obiettivo: alterare il registro pubblico senza che la modifica venga rilevata.

Dispositivo dell'elettore compromesso

Tipologia: attivo.

Contesto e risorse: un malware sul dispositivo dell'elettore può leggere o modificare dati prima che vengano cifrati o firmati.

Obiettivo: alterare la preferenza prima della cifratura, impersonare l'elettore o indurlo a credere che sia stata registrata una scheda diversa.

Coercizione e vendita del voto

Tipologia: attivo.

Contesto e risorse: un soggetto terzo può costringere o incentivare l'elettore a votare per una lista specifica e chiedere una prova del comportamento di voto.

Obiettivo: trasformare la ricevuta individuale in una prova del voto espresso.

Denial of Service

Tipologia: attivo.

Contesto e risorse: un avversario genera molte richieste verso RA o BB durante il periodo di voto, anche senza possedere credenziali valide.

Obiettivo: impedire agli elettori legittimi di completare la procedura di voto.

Collusione tra autorità

Tipologia: insider / attivo o passivo.

Contesto e risorse: due o più entità del sistema, ad esempio RA, BB, TA o un numero sufficiente di commissari, condividono le informazioni in loro possesso. La RA può conoscere l'associazione tra identità reale e pseudonimo, il BB osserva le schede cifrate e gli pseudonimi pubblici, mentre la TA accede ai voti in chiaro durante lo scrutinio.

Obiettivo: ricostruire l'associazione tra identità reale e preferenza di voto oppure anticipare o manipolare lo scrutinio.

Proprietà di Sicurezza e Resilienza

1. Confidenzialità, segretezza e pseudoanonimato

S.1 – Segretezza del voto.

La preferenza espressa dal singolo elettore deve rimanere confidenziale durante la fase di raccolta e fino allo scrutinio. Un osservatore esterno, il Bulletin Board o la Registration Authority non devono poter ricavare la lista scelta a partire dalla scheda cifrata.

S.2 – Pseudoanonimato.

Il sistema non garantisce anonimato forte, ma pseudoanonimato basato sulla separazione dei ruoli. La RA conosce l'identità reale ma non il voto. Il BB vede lo pseudonimo p_i e la scheda cifrata ma non l'identità reale. La TA accede ai voti in chiaro solo durante lo scrutinio ma non riceve l'elenco nominativo.

S.3 – Protezione dei canali.

Le comunicazioni tra elettore e RA, e tra elettore e BB, devono avvenire su canali protetti.

S.4 – Cifratura probabilistica.

La cifratura del voto deve essere non deterministica, cioè deve usare casualità fresca per ogni scheda.

S.5 – Robustezza rispetto a ciphertext malformati.

Il sistema di raccolta non deve comportarsi come un oracolo capace di rivelare informazioni sul contenuto dei voti o sulla chiave privata di scrutinio.

S.6 – Custodia distribuita della chiave di scrutinio.

La chiave privata necessaria alla decifratura dei voti non deve essere utilizzabile autonomamente da una singola entità prima della chiusura delle urne. Il sistema deve richiedere la cooperazione di almeno t commissari su n per recuperare la capacità di scrutinio. Questa proprietà riduce il rischio di decifratura anticipata o unilaterale, pur non eliminando il rischio di collusione tra almeno t commissari.

2. Integrità, autenticità e unicità**I.1 – Integrità delle schede registrate.**

Le schede registrate nel Bulletin Board non devono poter essere alterate, cancellate, sostituite o riordinate senza che la modifica diventi rilevabile.

I.2 – Registro append-only.

Ogni nuova entry viene aggiunta alla storia pubblica del registro; le entry già pubblicate non vengono modificate né cancellate.

I.3 – Integrità tramite funzioni hash.

Il sistema deve usare funzioni hash crittografiche adeguate per proteggere gli identificativi delle schede e i collegamenti del registro.

A.1 – Autenticità degli elettori.

Solo gli ingegneri riconosciuti come aventi diritto e autenticati presso la Registration Authority possono partecipare alla votazione.

A.2 – Unicità del voto finale.

Ciascun avente diritto deve avere al più un voto valido finale. Eventuali sostituzioni devono essere riconducibili alla stessa autorizzazione pseudonima, senza rivelare l'identità reale dell'elettore.

A.3 – Non falsificabilità.

Non deve essere possibile produrre autorizzazioni o pacchetti di voto apparentemente validi senza possedere le credenziali e i materiali crittografici necessari.

A.4 – Resistenza al replay.

Un pacchetto già accettato non deve poter essere conteggiato più di una volta.

A.5 – Tracciabilità delle sostituzioni.

Se l'elettore sostituisce il voto, il registro deve conservare la storia delle versioni. Ai fini dello scrutinio viene considerata solo l'ultima versione valida registrata prima della chiusura delle urne.

3. Verificabilità e trasparenza

V.1 – Verificabilità individuale.

Ogni elettore deve poter verificare autonomamente che la propria scheda cifrata sia stata inclusa nel Bulletin Board.

V.2 – Controllo pubblico del registro.

Osservatori esterni devono poter controllare l'integrità del registro, la validità delle firme e la presenza di una sola scheda finale per ciascuna autorizzazione pseudonima.

V.3 – Verificabilità universale parziale.

Chiunque deve poter verificare la coerenza numerica e la firma del risultato. Tuttavia, il pubblico non dispone di una prova crittografica della corretta decifratura di ogni singolo ciphertext.

T.1 – Trasparenza degli algoritmi.

Il sistema deve utilizzare algoritmi e protocolli crittografici pubblicamente noti.

T.2 – Esplicitazione delle assunzioni di fiducia.

Ogni assunzione di fiducia deve essere dichiarata e analizzata.

T.3 – Verifica individuale e coercizione.

La ricevuta non contiene il voto in chiaro e la possibilità di sostituire il voto prima della chiusura delle urne riduce il valore di una prova mostrata durante la votazione, ma non impedisce completamente la coercizione.

4. Efficienza e scalabilità

E.1 – Efficienza lato elettore.

Le operazioni richieste al singolo elettore devono avere costi computazionali contenuti.

E.2 – Efficienza lato Bulletin Board.

Per ogni voto accettato, il BB deve eseguire un numero limitato di operazioni, con costo per-voto sostanzialmente indipendente dal numero totale degli elettori.

E.3 – Scalabilità dello scrutinio.

Lo scrutinio deve crescere in modo ragionevole con il numero di schede finali (costo lineare).

E.4 – Scalabilità della verifica pubblica.

La verifica completa del registro ha costo lineare nel numero di entry pubblicate.

Completezza

Per completezza si intende il comportamento del sistema nel caso in cui tutte le parti coinvolte si comportino onestamente e seguano il protocollo. Sotto questa ipotesi:

- se l'ingegnere è iscritto all'Albo e si autentica correttamente presso la RA, riceve un'autorizzazione pseudonima valida e firmata;
- il client dell'elettore conserva in modo persistente e protetto lo stato pseudonimo, comprendente $t_i, p_i, \tau_i, (pk_i^{vote}, sk_i^{vote})$, la versione corrente e le ricevute ottenute;
- se l'elettore possiede un'autorizzazione valida e la corrispondente chiave pseudonima, può depositare una scheda cifrata presso il BB;
- se il pacchetto è ben formato, firmato correttamente e inviato entro il periodo di apertura, il BB lo registra nella hash chain e restituisce una ricevuta firmata;
- se l'elettore sostituisce il voto prima della chiusura, il BB registra la nuova versione senza cancellare le precedenti, fino a un massimo di $V_{\max}$ versioni per ciascun pseudonimo p_i ;
- alla chiusura delle urne, il BB pubblica un evento **CLOSE** nella hash chain e firma lo stato finale producendo SIG_{close} , che identifica in modo univoco lo stato ufficiale del registro;
- per ciascun pseudonimo p_i viene selezionata l'ultima versione valida registrata prima di **CLOSE**;
- con la cooperazione di almeno t commissari, K_{wrap} viene ricostruita tramite Shamir e sk_{TA_dec} viene recuperata temporaneamente dall'apertura autenticata di $blob_{TA}$;
- la TA decifra le schede finali valide, calcola i totali e pubblica il risultato firmato, riferito a h_{close} ;
- ogni elettore può verificare l'inclusione della propria scheda cifrata tramite la ricevuta e lo pseudonimo p_i ;
- chiunque può verificare l'integrità del registro, la validità delle firme τ_i e σ_i , ricalcolare i RID_i , controllare la corretta selezione delle schede finali e la coerenza numerica del risultato.

La completezza non implica anonimato perfetto, resistenza completa alla coercizione o verificabilità crittografica completa dello scrutinio.

Compromessi Progettuali e Assunzioni di Fiducia

Verificabilità individuale e resistenza alla coercizione

Il sistema privilegia la verificabilità individuale, ritenuta essenziale per la fiducia nel processo, ma dichiara che la resistenza alla coercizione non è pienamente garantita. La possibilità di sostituire il voto prima della chiusura mitiga parzialmente il rischio, poiché una ricevuta ottenuta durante la votazione non prova necessariamente quale scheda sarà conteggiata alla fine. Il numero massimo di sostituzioni è limitato a $V_{\max}$ versioni per ciascun pseudonimo p_i , bilanciando la mitigazione della coercizione con la protezione contro la saturazione del registro.

Segretezza del voto e verificabilità universale del tally

Il sistema non pubblica la corrispondenza tra ogni scheda cifrata e il voto in chiaro. La verificabilità universale del tally è solo parziale: il pubblico può verificare integrità, firme τ_i e σ_i , versioni, unicità per ciascun p_i e coerenza numerica, ma non può verificare autonomamente la corretta decifratura di ogni singolo ciphertext. Una verificabilità universale completa richiederebbe prove crittografiche di corretta decifratura, non incluse nel nucleo base.

Pseudoanonimato e separazione dei ruoli

La RA autentica gli elettori e conosce il collegamento tra identità reale e pseudonimo p_i . Il BB registra schede cifrate e pseudonimi ma non conosce l'identità reale. La TA decifra durante lo scrutinio ma non riceve l'elenco nominativo. Se RA, BB e TA colludessero, oppure se venissero combinati log e metadati, lo pseudoanonimato potrebbe essere indebolito. Per questo motivo, il protocollo richiede una chiara separazione organizzativa e tecnica tra le entità e una minimizzazione dei log non necessari.

Token non blindato

Nella versione base, la RA vede lo pseudonimo p_i e la chiave pk_i^{vote} prima di firmare l'autorizzazione τ_i , e può quindi conservare il collegamento tra identità reale e pseudonimo. L'adozione di blind signature richiederebbe un protocollo di firma cieca correttamente progettato e analizzato, con padding e controlli adeguati. Poiché tale costruzione non è inclusa nel nucleo base del progetto, si sceglie di non adottarla e di dichiarare esplicitamente il rischio residuo di collegabilità presso la RA.

Fiducia residua nella Tallying Authority

Nella versione base, il pubblico non dispone di prove crittografiche complete per verificare ogni decifratura. Si assume che la TA e i commissari seguano la procedura. Il risultato è firmato dalla TA e vincolato allo stato finale h_{close} del BB, garantendo che il tally si riferisca a uno stato del registro univoco e non ambiguo.

Integrità e disponibilità del Bulletin Board

La hash chain rende rilevabili alterazioni, cancellazioni o riordinamenti successivi alla pubblicazione. Alla chiusura delle urne, il BB firma lo stato finale del registro tramite $SIG_{close} = \text{Sign}(sk_{BB}, (election_id, h_{close}))$, impedendo la presentazione di viste divergenti del registro a soggetti diversi. Tuttavia, il protocollo non impedisce al BB di rifiutare o omettere una richiesta prima della sua prima pubblicazione. L'elettore deve conservare la ricevuta firmata e verificare l'inclusione della propria scheda.

Radice di fiducia iniziale

L'autenticità delle chiavi pubbliche dell'elezione si basa sulla pubblicazione sul portale istituzionale autenticato dell'Ordine degli Ingegneri. Tale canale costituisce la radice di

fiducia iniziale del protocollo. Se il portale venisse compromesso, un attaccante potrebbe sostituire le chiavi pubbliche e intercettare o alterare la votazione. L'integrità del portale è un'assunzione di fiducia infrastrutturale non risolvibile dal solo protocollo crittografico.

Persistenza dello stato dell'elettore

Il protocollo assume che il dispositivo dell'elettore conservi in modo integro e protetto lo stato pseudonimo (t_i , p_i , sk_i^{vote} , τ_i , la versione corrente e le ricevute). In caso di perdita definitiva dello stato locale, l'elettore non può più depositare nuove schede né sostituire il voto, ma l'ultima scheda validamente registrata nel BB resta conteggiata nello scrutinio.

Affidabilità del dispositivo dell'elettore

Il protocollo protegge i messaggi dopo la loro generazione, ma non può garantire che il dispositivo rispetti la volontà dell'elettore. Un malware potrebbe alterare il voto prima della cifratura, rubare t_i o sk_i^{vote} , o falsificare la verifica locale. Si assume che il dispositivo non sia compromesso.

Disponibilità dell'infrastruttura

Attacchi DoS, guasti di rete e indisponibilità dei server devono essere mitigati tramite misure operative e infrastrutturali, come rate limiting, ridondanza e procedure di emergenza. Il protocollo crittografico non risolve queste minacce.

WP 2: Soluzione

Strumenti crittografici utilizzati

Strumento	Scopo nel protocollo
Cifratura a chiave pubblica probabilistica	Protegge il contenuto del voto. L'elettore cifra il codice della lista scelta con la chiave pubblica della TA. La cifratura usa casualità fresca. Nel prototipo: RSA-OAEP.
Firma digitale	Garantisce autenticità e integrità dei principali messaggi. La RA firma le autorizzazioni, l'elettore firma il pacchetto con la chiave pseudonima, il BB firma le ricevute e la TA firma il risultato. Nel prototipo: RSA-PSS.
Funzione hash crittografica	Calcolo di $p_i = H(t_i)$, identificativi delle schede (RID_i), costruzione della hash chain del BB. Nel prototipo: SHA-256.

Strumento	Scopo nel protocollo
Autenticazione con password, salt e hash su TLS	Autentica nominativamente l'elettore presso la RA. TLS protegge il canale; salt e hash evitano di memorizzare la password in chiaro.
Registro append-only con hash chain	Permette di rilevare alterazioni, cancellazioni, inserimenti o riordinamenti. Ogni entry viene collegata alla precedente tramite hash.
Secret Sharing di Shamir	Custodia distribuita della chiave di scrutinio. La chiave viene cifrata con K_{wrap} e Shamir viene applicato a K_{wrap} . Almeno t commissari su n possono ricostruire K_{wrap} .
Cifratura simmetrica autenticata	Protegge la chiave sk_{TA_dec} con K_{wrap} , producendo un blob che può essere aperto solo dopo la ricostruzione. Nel prototipo: AES-256-CBC + HMAC-SHA256 con chiavi indipendenti (Encrypt-then-Authenticate)."

Non vengono utilizzate costruzioni crittografiche manuali o non standard. Shamir Secret Sharing viene usato solo come meccanismo di custodia distribuita e non realizza una vera decifratura a soglia.

Sintesi delle chiavi

Chiave	Proprietario	Uso nel protocollo
$pk_{TA_enc} / sk_{TA_dec}$	TA	Cifratura e decifratura dei voti. sk_{TA_dec} viene cifrata con K_{wrap} e recuperata solo durante lo scrutinio.
$pk_{TA_sig} / sk_{TA_sig}$	TA	Firma dei parametri pubblici e del risultato finale. Coppia distinta dalla precedente.
pk_{RA} / sk_{RA}	RA	Firma delle autorizzazioni pseudonime. Il BB usa pk_{RA} per verificarle.
pk_{BB} / sk_{BB}	BB	Firma delle ricevute di deposito (ACK) e dello stato finale del registro (SIG_{close}).
$pk_i^{vote} / sk_i^{vote}$	Elettore	Coppia pseudonima generata per la singola elezione. sk_i^{vote} firma il pacchetto di voto.
t_i	Elettore	Segreto casuale generato localmente, dal quale l'elettore deriva lo pseudonimo p_i . Non viene mai trasmesso al BB. Serve all'elettore per ricalcolare p_i e ritrovare la propria entry durante la verifica individuale.

Chiave	Proprietario	Uso nel protocollo
$p_i = H(t_i)$	Elettore / pubblico	Pseudonimo pubblico dell'elettore. La titolarità del voto non è dimostrata dalla conoscenza di t_i , ma dal possesso della chiave privata sk_i^{vote} , che consente di produrre la firma σ_i sul pacchetto di voto.
K_{wrap}	Setup / Commissari	Chiave simmetrica per cifrare sk_{TA_dec} . Divisa tra i commissari tramite Shamir.
$s_1, \dots, s_n$	Commissari	Quote Shamir di K_{wrap} . Almeno t quote sono necessarie per ricostruire K_{wrap} .
$blob_{TA}$	TA / sistema	sk_{TA_dec} serializzata e cifrata con K_{wrap} .
$salt_i, verifier_i$	RA	Autenticazione dell'elettore. La password non è memorizzata in chiaro.

Fase 0 — Configurazione del sistema

Prima dell'apertura delle urne, la commissione elettorale configura l'elezione. Vengono pubblicati: *election_id*, elenco delle liste ammesse con codice identificativo, periodo di apertura e chiusura delle urne, numero totale degli aventi diritto, pk_{TA_enc} , pk_{TA_sig} , pk_{RA} , pk_{BB} , i parametri pubblici dello schema a soglia (t , n) e il numero massimo di versioni consentite per ciascun pseudonimo (V_{max} , ad esempio $V_{max} = 3$).

I parametri e le chiavi pubbliche dell'elezione vengono pubblicati prima dell'apertura sul portale istituzionale autenticato dell'Ordine degli Ingegneri. Tale canale costituisce la **radice di fiducia iniziale** del protocollo: ogni elettore e osservatore può verificare l'autenticità delle chiavi pubbliche confrontandole con quelle pubblicate sul portale ufficiale.

La TA genera due coppie di chiavi distinte: una per la cifratura e decifratura dei voti (pk_{TA_enc} , sk_{TA_dec}) e una per firmare parametri e risultati (pk_{TA_sig} , sk_{TA_sig}).

La RA mantiene internamente l'elenco nominativo degli aventi diritto, che non viene pubblicato.

Il BB inizializza il registro pubblico append-only con il primo valore della hash chain:

$$h_0 = H("BB-GENESIS" || election_id || params_hash)$$

Custodia distribuita della chiave di scrutinio tramite Shamir

La chiave privata sk_{TA_dec} non viene divisa direttamente. La TA genera una chiave simmetrica casuale K_{wrap} e cifra la chiave privata serializzata:

$$blob_{TA} = \text{Enc}_{\text{sym}}(K_{wrap}, \text{Serialize}(sk_{TA_dec}))$$

K_{wrap} viene suddivisa tra i commissari tramite Shamir Secret Sharing con parametri (t, n), ad esempio $t = 4$ e $n = 7$. Shamir costruisce un polinomio casuale di grado $t - 1$ in

un campo finito $\mathbb{Z}_q$, dove q è un primo maggiore di K_{wrap} :

$$g(x) = K_{wrap} + a_1x + a_2x^2 + \dots + a_{t-1}x^{t-1} \pmod{q}$$

con coefficienti $a_1, \dots, a_{t-1}$ scelti casualmente in $\mathbb{Z}_q$. Ogni commissario i riceve la quota $s_i = (i, g(i) \pmod{q})$. Almeno t quote con indici distinti permettono di ricostruire $K_{wrap} = g(0)$ tramite interpolazione di Lagrange; con meno di t quote non si ottiene alcuna informazione su K_{wrap} .

Una singola quota Shamir non è verificabile autonomamente in modo crittografico. Una quota alterata produce una K_{wrap} errata, che viene rilevata al momento dell'apertura autenticata di $blob_{TA}$: la verifica del MAC o della cifratura autenticata fallisce, impedendo il recupero di sk_{TA_dec} .

Dopo la distribuzione, K_{wrap} in chiaro e sk_{TA_dec} in chiaro vengono eliminate dall'ambiente di configurazione.

Fase 1 — Autenticazione ed emissione dell'autorizzazione pseudonima

L'elettore accede al portale della RA usando le proprie credenziali istituzionali. Nel caso base, la RA memorizza per ciascun utente:

$$verifier_i = \text{PasswordHash}(password_i, salt_i)$$

Se l'autenticazione ha successo, la RA verifica che l'utente sia nell'elenco degli aventi diritto e non abbia già ricevuto un'autorizzazione. L'elettore genera localmente:

- t_i : un segreto casuale valido solo per questa elezione, che non verrà mai trasmesso al BB;
- $p_i = H(t_i)$: lo pseudonimo pubblico, derivato dal segreto tramite hash;
- $(pk_i^{vote}, sk_i^{vote})$: una coppia di chiavi pseudonima per firmare il voto.

L'elettore invia alla RA lo pseudonimo pubblico e la chiave pseudonima:

$$M_{AUTH} = (election_id, p_i, pk_i^{vote})$$

La RA firma il messaggio e restituisce l'autorizzazione:

$$\tau_i = \text{Sign}(sk_{RA}, M_{AUTH})$$

Poiché M_{AUTH} contiene solo p_i e non t_i , la firma τ_i è verificabile da chiunque conosca p_i e pk_{RA} , senza rivelare il segreto t_i . La RA registra che l'elettore ha già ricevuto un'autorizzazione. Dopo l'emissione dell'autorizzazione, il client dell'elettore conserva in modo persistente e protetto lo stato pseudonimo relativo all'elezione, comprendente t_i , p_i , la coppia $(pk_i^{vote}, sk_i^{vote})$, l'autorizzazione τ_i , la versione corrente v_i e le ricevute ottenute dal Bulletin Board. La chiusura e la successiva riapertura dell'applicazione non comportano quindi la perdita di tali informazioni. Il metodo concreto di memorizzazione protetta sarà definito e implementato nel WP4. Nella versione base, la RA conosce il collegamento tra identità reale, pseudonimo p_i e chiave pk_i^{vote} , ma non conosce la preferenza.

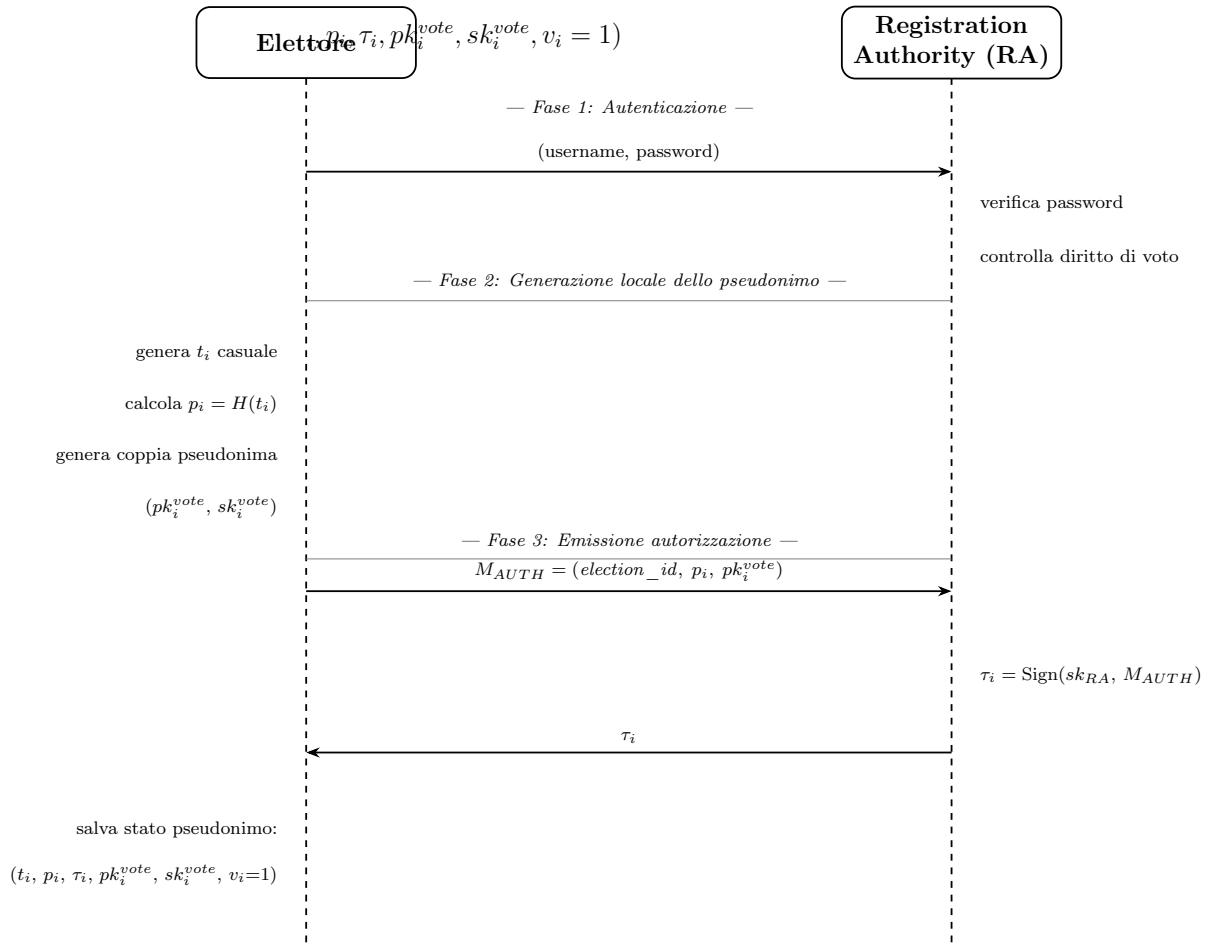


Figura 2: Diagramma di sequenza: autenticazione ed emissione dell'autorizzazione pseudonima (Fase 1).

Fase 2 — Preparazione e invio del voto

L'elettore seleziona il codice della lista prescelta $j \in \{001, \dots, K\}$ e lo cifra con casualità fresca r :

$$c = \text{Enc}(pk_{TA_enc}, j; r)$$

Per il primo deposito, l'elettore imposta $v_i = 1$ e costruisce il messaggio:

$$M_{BALLOT_i} = (election_id, p_i, c, pk_i^{vote}, v_i)$$

Firma il messaggio con la chiave pseudonima:

$$\sigma_i = \text{Sign}(sk_i^{vote}, M_{BALLOT_i})$$

Il pacchetto inviato al Bulletin Board è:

$$MSG = (c, p_i, pk_i^{vote}, \tau_i, v_i, \sigma_i)$$

Il pacchetto non contiene l'identità reale dell'elettore né il segreto t_i . Lo pseudonimo p_i è un hash unidirezionale: chiunque può usarlo per verificare τ_i e σ_i con le rispettive chiavi pubbliche, ma non può risalire a t_i . La firma pseudonima σ_i dimostra il possesso della chiave sk_i^{vote} : il solo possesso di p_i e τ_i non è sufficiente per generare o sostituire un voto valido.

Fase 3 — Raccolta e validazione sul Bulletin Board

Quando il BB riceve $MSG = (c, p_i, pk_i^{vote}, \tau_i, v_i, \sigma_i)$, esegue i seguenti controlli:

1. Verifica l'autorizzazione della RA: $\text{Verify}(pk_{RA}, (election_id, p_i, pk_i^{vote}), \tau_i) = 1$.
2. Verifica la firma pseudonima: $\text{Verify}(pk_i^{vote}, (election_id, p_i, c, pk_i^{vote}, v_i), \sigma_i) = 1$.
3. Controlla che l'elezione sia ancora aperta.
4. Controlla la versione del voto:
 - se p_i non è presente nel registro, accetta solo se $v_i = 1$;
 - se p_i è presente, accetta una sostituzione solo se la versione è consecutiva e non supera $V_{\max}$;
 - se la versione richiesta è maggiore di $V_{\max}$, il pacchetto viene rifiutato;
 - se il pacchetto è identico a uno già ricevuto, lo tratta come replay.

Se i controlli passano, il BB calcola l'identificativo pubblico della scheda:

$$RID_i = H(election_id || c || p_i || pk_i^{vote} || v_i || \sigma_i)$$

e costruisce una entry del registro che include tutte le informazioni necessarie alla verifica pubblica:

$$ENTRY_i = (\text{BALLOT}, c, p_i, pk_i^{vote}, \tau_i, v_i, \sigma_i, RID_i, timestamp)$$

Poiché τ_i e σ_i sono pubblicati insieme a p_i e pk_i^{vote} , chiunque può: verificare τ_i con pk_{RA} per controllare che l'autorizzazione sia autentica; verificare σ_i con pk_i^{vote} per controllare che il pacchetto sia stato firmato dal titolare della coppia pseudonima; ricalcolare RID_i ; controllare versioni e hash chain.

Il BB aggiorna la hash chain:

$$h_k = H(h_{k-1} || k || H(ENTRY_i))$$

e restituisce una ricevuta firmata:

$$ACK_i = \text{Sign}(sk_{BB}, (election_id, k, RID_i, h_k))$$

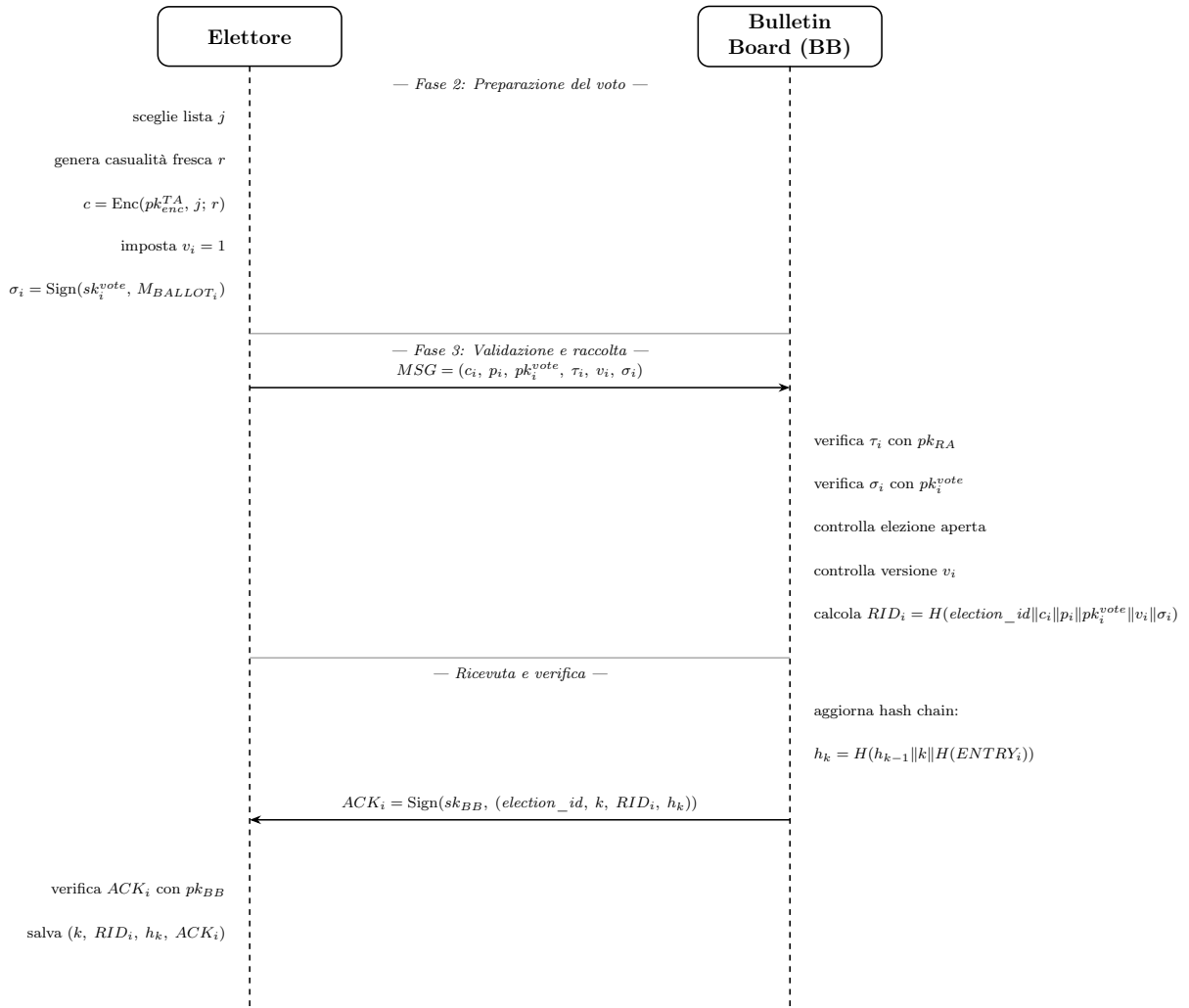


Figura 3: Diagramma di sequenza: preparazione, invio e raccolta del voto (Fasi 2–3).

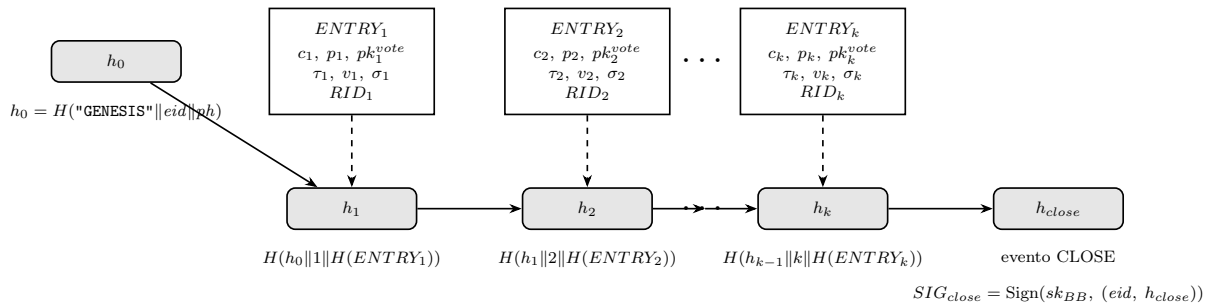


Figura 4: Struttura della hash chain del Bulletin Board.

Fase 4 — Sostituzione del voto

Se l'applicazione è stata chiusa dopo il primo deposito, l'elettore riapre lo stato pseudonimo conservato localmente sul proprio dispositivo. Il client riutilizza la stessa autoriz-

zazione τ_i , lo stesso pseudonimo p_i e la stessa chiave privata sk_i^{vote} per firmare la nuova versione della scheda, senza dover interagire nuovamente con la RA. Prima della chiusura delle urne, l'elettore può sostituire il proprio voto. Sceglie una nuova lista j' , calcola $c' = \text{Enc}(pk_{TA_enc}, j'; r')$ con nuova casualità, incrementa $v'_i = v_i + 1$ e firma:

$$\sigma'_i = \text{Sign}(sk_i^{vote}, (election_id, p_i, c', pk_i^{vote}, v'_i))$$

Il BB accetta la sostituzione solo se l'autorizzazione è valida, la firma pseudonima è valida, viene usata la stessa pk_i^{vote} , la versione è consecutiva, non supera $V_{\max}$ e le urne sono ancora aperte. La vecchia entry non viene cancellata. Ai fini dello scrutinio, sarà considerata solo la versione valida più alta registrata prima della chiusura.

Il limite $V_{\max}$ impedisce che un elettore o un attaccante in possesso di sk_i^{vote} generi un numero arbitrario di sostituzioni, riducendo il rischio di saturazione del registro. Con $V_{\max} = 3$, l'elettore può depositare il voto originale e sostituirlo al massimo due volte.

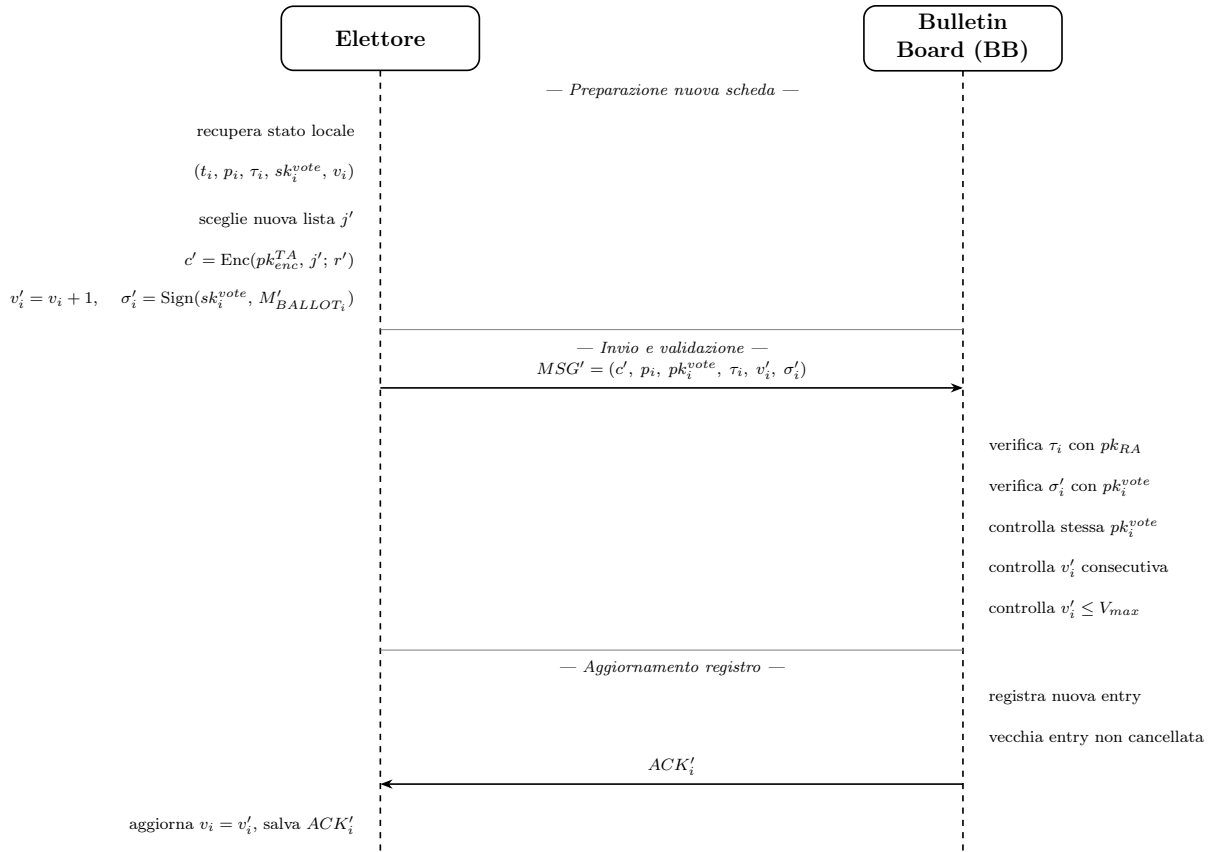


Figura 5: Diagramma di sequenza: sostituzione del voto (Fase 4).

Fase 5 — Chiusura delle urne e scrutinio

Alla scadenza del periodo di voto, il BB pubblica un evento **CLOSE** inserito nella hash chain, producendo lo stato finale h_{close} . Il BB firma esplicitamente lo stato finale del

registro:

$$SIG_{close} = \text{Sign}(sk_{BB}, (election_id, h_{close}))$$

Questa firma identifica in modo univoco e non ambiguo l'unico stato finale ufficiale del registro. La hash chain da sola rende rilevabili le manomissioni successive, ma SIG_{close} impedisce che vengano presentate viste divergenti del registro a soggetti diversi.

L'insieme delle schede da scrutinare è determinato in modo pubblico: per ogni p_i si considera solo la versione valida più alta registrata prima di **CLOSE**, con firma pseudonima e autorizzazione RA valide.

Almeno t commissari presentano le proprie quote s_i . Il sistema ricostruisce la chiave simmetrica:

$$K_{wrap} = \text{ShamirRecover}(s_{i_1}, \dots, s_{i_t})$$

La TA verifica l'integrità di $blob_{TA}$ tramite il MAC della cifratura autenticata. Se la verifica ha successo, apre il blob e recupera la chiave di scrutinio:

$$sk_{TA_dec} = \text{Dec}_{\text{sym}}(K_{wrap}, blob_{TA})$$

Se la verifica del MAC fallisce, la ricostruzione di K_{wrap} è da considerarsi errata e lo scrutinio non può procedere. La TA decifra le schede finali valide $j_i = \text{Dec}(sk_{TA_dec}, c_i)$, verifica che $j_i \in \{001, \dots, K\}$, calcola i totali N_j e firma il risultato:

$$SIG_{tally} = \text{Sign}(sk_{TA_sig}, (election_id, h_{close}, \{N_1, \dots, N_K\}, N_{anomale}))$$

Non viene pubblicata la corrispondenza tra ogni singolo ciphertext e il voto decifrato. Al termine, K_{wrap} e sk_{TA_dec} vengono cancellate.

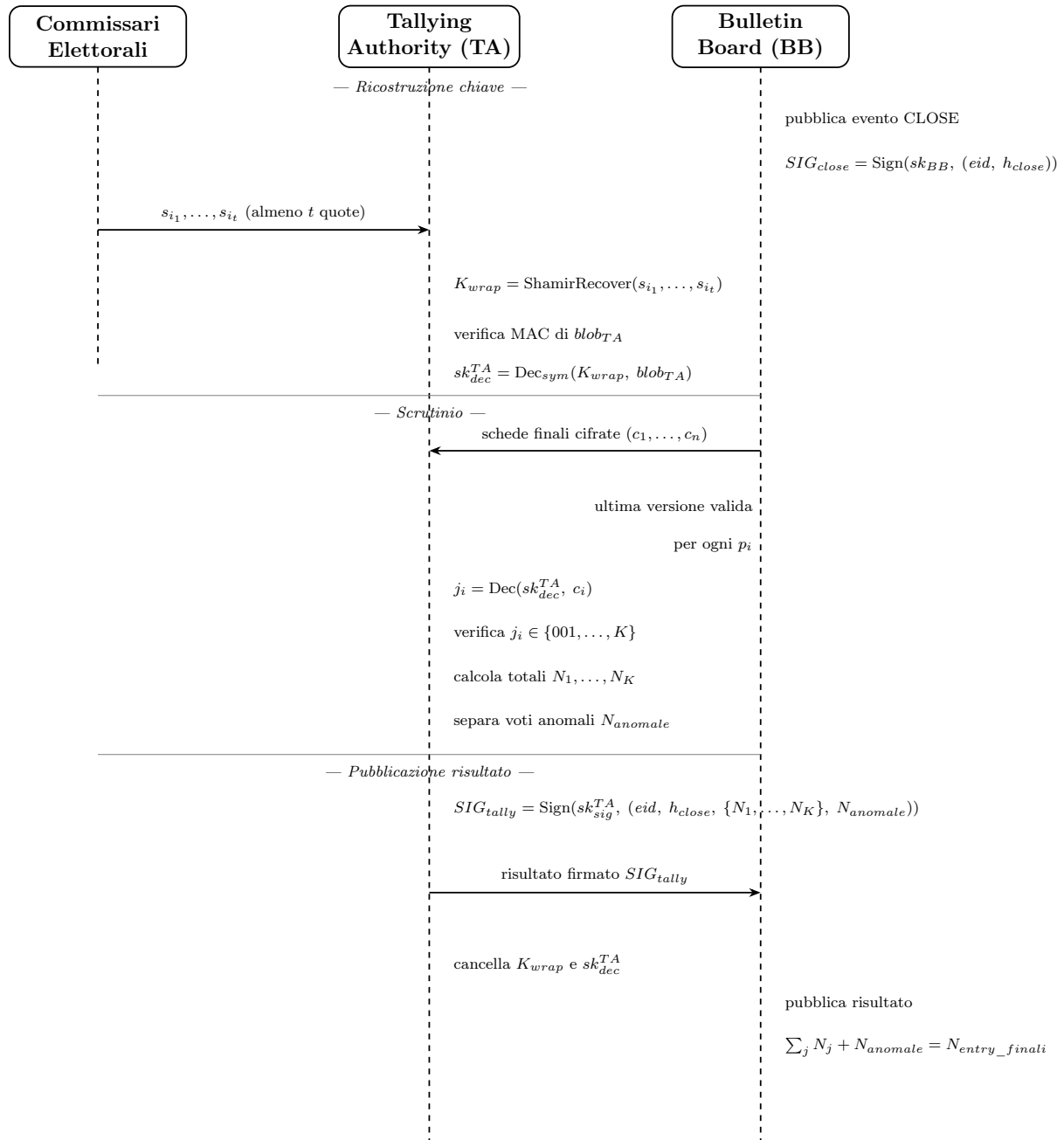


Figura 6: Diagramma di sequenza: chiusura delle urne e scrutinio (Fase 5).

Fase 6 — Verifica

Verifica individuale

L'elettore possiede il segreto t_i e la ricevuta (k, RID_i, h_k, ACK_i) . Per prima cosa calcola $p_i = H(t_i)$ e individua la propria entry sul BB cercando lo pseudonimo p_i . Poi verifica la

ricevuta:

$$\text{Verify}(pk_{BB}, (election_id, k, RID_i, h_k), ACK_i) = 1$$

Infine controlla che nel BB esista una entry con lo stesso RID_i appartenente alla hash chain che conduce a h_{close} .

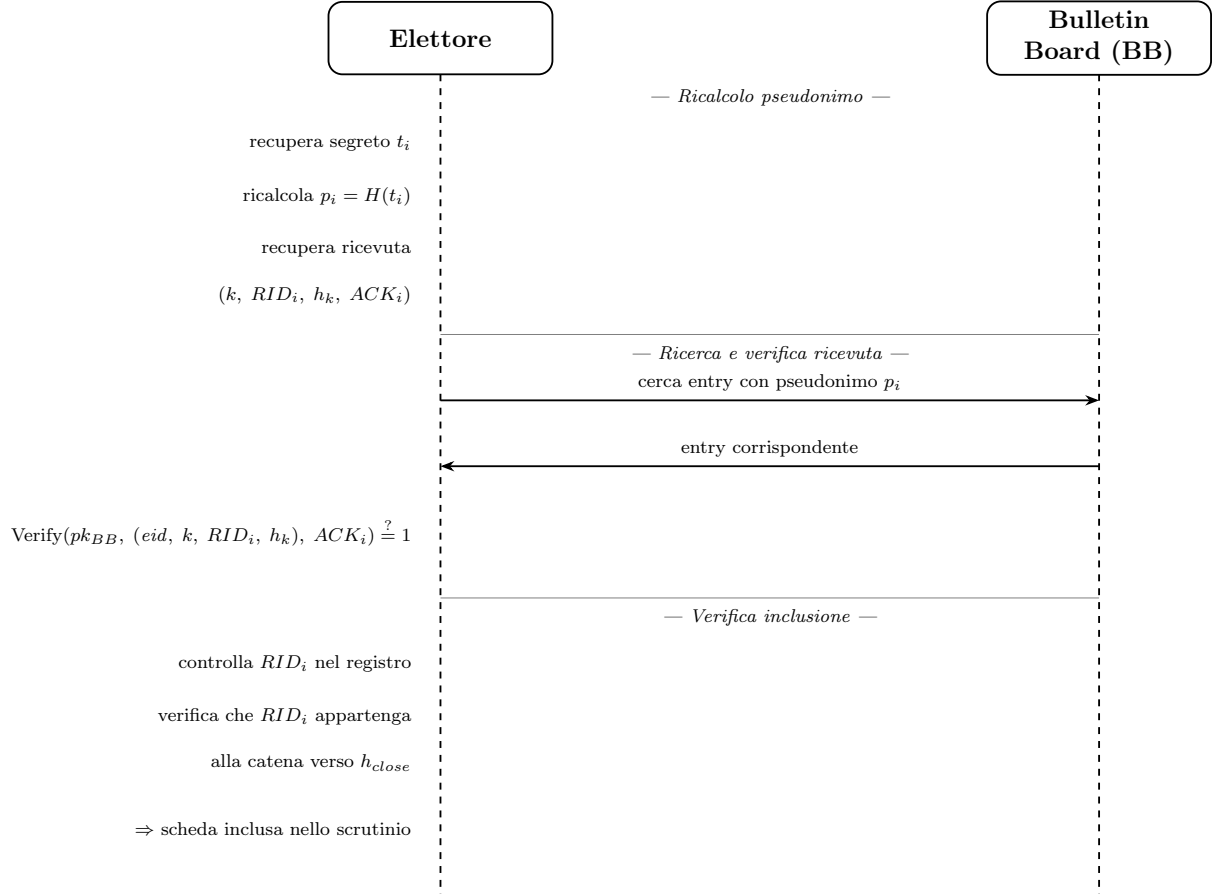


Figura 7: Diagramma di sequenza: verifica individuale (Fase 6).

Controllo pubblico del registro

Chiunque può controllare: validità delle firme RA (τ_i) e delle firme pseudonime (σ_i) usando le chiavi pubbliche pk_{RA} e pk_i^{vote} presenti nelle entry; correttezza della hash chain; assenza di modifiche dopo la pubblicazione; corretta selezione di una sola scheda finale per ciascun p_i ; presenza dell'evento **CLOSE** e validità di SIG_{close} tramite pk_{BB} ; corrispondenza tra h_{close} in SIG_{close} e h_{close} in SIG_{tally} ; validità della firma della TA sul risultato tramite pk_{TA_sig} ; ricalcolo pubblico dei RID_i ; coerenza numerica:

$$\sum_j N_j + N_{anomale} = N_{entry_finali}$$

Limite della verificabilità universale

La versione base non fornisce una prova pubblica della corretta decifratura di ogni singolo ciphertext. La correttezza del tally richiede una fiducia residua nella TA e nei commissari.

Efficienza attesa e scalabilità

Per ciascun elettore, il protocollo richiede un numero costante di operazioni crittografiche. Lo scrutinio è lineare nel numero di voti conteggiati. La verifica pubblica del registro è lineare nel numero di entry pubblicate.

Estensioni possibili non incluse nel prototipo base

La versione base è volutamente limitata per rimanere implementabile nel WP4. Sono considerate estensioni possibili:

- uso di un Merkle tree per impegnare pubblicamente l'elenco degli aventi diritto senza pubblicarlo;
- sostituzione del BB centralizzato con un registro distribuito basato su blockchain permissioned;
- mirror indipendenti del Bulletin Board e checkpoint periodici firmati;
- vera decifratura a soglia, senza ricostruire la chiave completa;
- prove crittografiche pubbliche di corretta decifratura (zero-knowledge proof);
- uso di blind signature per l'emissione dell'autorizzazione pseudonima;
- meccanismi più forti di resistenza alla coercizione;
- autenticazione forte con certificati personali X.509.

WP3: Analisi della Sicurezza

In questo work package viene analizzata la sicurezza della soluzione proposta nel WP2 rispetto al modello definito nel WP1. L'obiettivo non è fornire una dimostrazione formale completa, ma verificare che le scelte progettuali siano coerenti con le minacce individuate, evidenziando anche i limiti residui e i compromessi non completamente risolti.

La soluzione viene valutata rispetto alle principali proprietà richieste: autenticità, unicità, pseudoanonimato, segretezza del voto, custodia distribuita della chiave di scrutinio, integrità del registro, verificabilità individuale, controllo pubblico del registro, verificabilità universale parziale, resistenza alla coercizione, disponibilità ed efficienza.

La versione base del protocollo non pretende di ottenere una sicurezza perfetta. Alcune proprietà, come la resistenza alla coercizione e la verificabilità universale completa dello scrutinio, sono garantite solo parzialmente. Questa scelta è coerente con il compromesso progettuale dichiarato nel WP1.

Obiettivo e metodo dell'analisi

L'analisi viene condotta confrontando, per ciascuna proprietà di sicurezza, i meccanismi introdotti nel WP2 e il relativo rischio residuo. Si considera un avversario esterno computazionalmente limitato e si distinguono minacce dovute a entità interne curiose o disoneste.

L'analisi considera i seguenti aspetti:

- correttezza dell'autenticazione presso la RA;
- non falsificabilità delle autorizzazioni pseudonime;
- protezione del voto tramite cifratura probabilistica;
- autenticità dei pacchetti di voto tramite firma pseudonima;
- custodia distribuita della chiave di scrutinio tramite Shamir Secret Sharing;
- integrità del Bulletin Board tramite registro append-only e hash chain;
- gestione di replay e sostituzioni del voto;
- scrutinio solo dopo l'evento di chiusura;
- verifica individuale mediante ricevuta;
- controllo pubblico del registro e della coerenza numerica del risultato;
- limiti residui dovuti a collusione, coercizione, dispositivi compromessi e assenza di prove pubbliche di corretta decifratura.

Analisi rispetto alle proprietà del WP1

Proprietà	Meccanismo	Rischio residuo
Autenticità (A.1)	Credenziali istituzionali presso la RA; autorizzazione firmata	Furto credenziali; compromissione sk_{RA}
Unicità (A.2)	τ_i Una sola τ_i per elezione; BB traccia p_i e versioni	Race condition; errori di implementazione
Pseudoanonimato (S.2)	Separazione RA / BB / TA; token non blindato	Collusione RA-TA; correlazione via metadati
Segretezza del voto (S.1)	RSA-OAEP con casualità fresca	Qualità della casualità; sk_{dec}^{TA} esposta in scrutinio
Custodia distribuita (S.6)	K_{wrap} suddivisa con Shamir (t, n) ; $blob_{TA}$ con AES-CBC + HMAC	Collusione $\geq t$ commissari; non è vera threshold decryption
Integrità registro (I.1–I.3)	Hash chain append-only; RID_i ; SIG_{close}	BB può omettere prima della pubblicazione
Non falsificabilità (A.3)	τ_i firmata da RA; σ_i firmata con sk_i^{vote}	Compromissione chiavi private
Resistenza replay (A.4)	Controllo pacchetti duplicati; versione consecutiva	Invii concorrenti; errori di sincronizzazione
Verificabilità individuale (V.1)	Ricevuta ACK_i firmata dal BB	Prova inclusione, non contenuto in chiaro
Controllo pubblico (V.2)	Firme, hash chain, RID_i ricalcolabili, coerenza numerica	Non prova corretta decifratura
Verificabilità universale (V.3)	Coerenza numerica e firma SIG_{tally}	Parziale: fiducia residua nella TA
Resistenza coercizione (T.3)	Ricevuta senza voto in chiaro; sostituzione con V_{max}	Elettore può collaborare col coercitore
Disponibilità	Rate limiting; ridondanza; logging	DoS resta problema infrastrutturale

Tabella 4: Riepilogo: proprietà, meccanismi e rischi residui.

Proprietà	Meccanismo nel WP2	Rischio residuo
Autenticità	La RA autentica nominativamente l'elettore tramite credenziali istituzionali. Dopo l'autenticazione, rilascia un'autorizzazione pseudonima firmata, valida solo per quella elezione. Il BB accetta voti solo se l'autorizzazione della RA è valida.	La sicurezza dipende dalla robustezza delle credenziali, dalla protezione del database della RA e dalla chiave privata della RA. Il furto delle credenziali istituzionali può consentire l'impersonificazione.
Unicità	Ogni elettore riceve al massimo una autorizzazione per elezione. Il BB usa lo pseudonimo pubblico p_i per riconoscere i depositi associati allo stesso elettore. In caso di sostituzione, viene conteggiata solo la versione valida più alta registrata prima della chiusura.	La proprietà dipende dalla corretta gestione dello stato da parte della RA e del BB. Errori di implementazione o race condition potrebbero permettere comportamenti anomali.
Pseudoanonimato	La RA conosce l'identità reale e lo pseudonimo p_i , ma non il voto in chiaro. Il BB vede p_i e la scheda cifrata, ma non l'identità reale. La TA decifra i voti finali, ma non riceve l'elenco nominativo.	Lo pseudoanonimato dipende dalla separazione tra RA, BB e TA. Una collusione tra RA e TA, eventualmente aiutata da metadati, potrebbe ricostruire l'associazione identità-voto.
Segretezza del voto	Il voto è cifrato con la chiave pubblica della TA usando cifratura probabilistica. Due voti uguali producono normalmente ciphertext diversi.	La segretezza dipende dalla sicurezza dello schema di cifratura, dalla qualità della casualità e dalla protezione della chiave privata della TA. Durante lo scrutinio la TA accede ai voti in chiaro.
Custodia distribuita della chiave	sk_{TA_dec} viene cifrata con K_{wrap} , suddivisa tra i commissari tramite Shamir. Solo almeno t quote su n permettono di ricostruire K_{wrap} .	Se almeno t commissari colludono, possono ricostruire K_{wrap} . Non si tratta di vera threshold decryption: durante lo scrutinio la chiave completa viene recuperata nell'ambiente della TA.
Integrità del registro	Il BB registra ogni voto in una sequenza append-only. Ogni entry è collegata alla precedente tramite hash chain. Alterazioni, cancellazioni o riordinamenti diventano rilevabili.	La hash chain rende il registro tamper-evident, ma non impedisce al BB di rifiutare o omettere una richiesta prima della sua pubblicazione.

Proprietà	Meccanismo nel WP2	Rischio residuo
Autenticità dei messaggi	L'autorizzazione è firmata dalla RA. Il pacchetto è firmato dall'elettore con la chiave pseudonima. La ricevuta è firmata dal BB. Il risultato è firmato dalla TA.	La sicurezza dipende dalla corretta verifica delle firme e dalla separazione delle chiavi. Una chiave privata compromessa permette di falsificare i messaggi del relativo ruolo.
Replay attack	Un pacchetto identico già ricevuto viene riconosciuto come replay. Una sostituzione viene accettata solo se usa la stessa chiave pseudonima e una versione consecutiva.	È necessario che il BB memorizzi correttamente l'ultima versione valida. Invii concorrenti o errori di sincronizzazione potrebbero creare problemi.
Sostituzione del voto	L'elettore può inviare una nuova scheda con versione incrementata, fino a un massimo di $V_{\max}$ versioni. La vecchia entry resta nel registro, ma viene conteggiata solo l'ultima versione valida.	Se la chiave privata pseudonima viene rubata, un attaccante potrebbe sostituire il voto fino alla chiusura. Se invece lo stato pseudonimo viene perso o cancellato, l'elettore non può effettuare ulteriori sostituzioni; la scheda già registrata rimane valida.
Verificabilità individuale	L'elettore riceve una ricevuta firmata dal BB contenente indice, identificativo della scheda e stato della catena.	La ricevuta prova l'inclusione del ciphertext, non il contenuto in chiaro del voto né la correttezza della successiva decifratura.
Controllo pubblico del registro	Chiunque può verificare τ_i con pk_{RA} , σ_i con pk_i^{vote} , ricalcolare i RID_i , controllare la hash chain, verificare SIG_{close} con pk_{BB} , confrontare h_{close} tra SIG_{close} e SIG_{tally} , e controllare la coerenza numerica.	Il controllo pubblico non prova che ogni ciphertext sia stato decifrato correttamente. La verificabilità universale del tally resta parziale.
Coercizione	La ricevuta non contiene il voto in chiaro. La sostituzione del voto rende non definitiva una ricevuta ottenuta prima della chiusura.	La coercizione non è eliminata. L'elettore potrebbe mostrare informazioni locali aggiuntive.
Disponibilità	Il protocollo può essere affiancato da rate limiting, logging, autenticazione preliminare e ridondanza infrastrutturale.	Gli attacchi DoS non sono risolti dal protocollo crittografico e restano un problema infrastrutturale.

Proprietà	Meccanismo nel WP2	Rischio residuo
Efficienza	Ogni elettore esegue un numero costante di operazioni. Il BB aggiorna la hash chain in tempo costante. Lo scrutinio è lineare nel numero di schede finali.	Firma e cifratura a chiave pubblica sono più costose delle sole operazioni hash. La verifica cresce linearmente con il numero di eventi pubblicati.

Analisi delle minacce e delle contromisure

Minaccia	Contromisura prevista	Osservazioni / limite residuo
Attaccante passivo sulla rete	Voto cifrato con chiave pubblica della TA. Cifratura probabilistica con casualità fresca. Canali protetti tramite TLS.	La sicurezza dipende dalla qualità della casualità, dalla corretta implementazione e dalla protezione dei metadati.
Attacchi alla segretezza (COA/KPA/CPA)	Voti uguali producono ciphertext diversi. L'avversario non può costruire una tabella voto-ciphertext.	Non deve essere usata cifratura deterministica. Il riuso della casualità comprometterebbe la protezione.
Pacchetti malformati	Il BB non decifra i voti durante la raccolta. Accetta solo pacchetti con autorizzazione RA e firma pseudonima valide.	Errori durante lo scrutinio devono essere gestiti in modo uniforme per evitare informazioni laterali.
Contraffazione di autorizzazioni	Solo la RA può firmare autorizzazioni valide. Il BB verifica la firma della RA prima di accettare un voto.	Se la chiave privata della RA viene compromessa, un attaccante può generare autorizzazioni false.
Iniezione di voti falsi	Il voto deve essere accompagnato da autorizzazione RA valida e firma pseudonima.	Il solo possesso di p_i non basta, ma la compromissione della chiave pseudonima sk_i^{vote} permette sostituzioni.
Replay attack	Il BB riconosce pacchetti identici già registrati. Le sostituzioni sono ammesse solo con versione consecutiva e prima di CLOSE.	La gestione delle versioni deve essere atomica e coerente.

Minaccia	Contromisura prevista	Osservazioni / limite residuo
Furto dello pseudonimo p_i	Lo pseudonimo p_i è associato a una chiave pubblica pseudonima pk_i^{vote} . Per produrre o sostituire un voto valido serve la firma con la corrispondente chiave privata sk_i^{vote} .	Se l'attaccante ruba anche la chiave privata pseudonima, può agire al posto dell'elettore.
RA curiosa	La RA conosce identità e pseudonimo, ma non il voto in chiaro.	La collusione RA-TA rompe lo pseudoanonimato. I metadati devono essere minimizzati.
TA o commissari disonesti	K_{wrap} suddivisa con Shamir. Meno di t commissari non possono ricostruire. Scrutinio solo dopo CLOSE. Risultato firmato e riferito a h_{close} .	Se almeno t commissari colludono, possono ricostruire K_{wrap} . Senza prove di corretta decifratura, fiducia residua nella TA.
BB disonesto	Hash chain tamper-evident. SIG_{close} firmata dal BB identifica lo stato finale ufficiale. Ricevute firmate per contestare l'assenza di schede.	Il BB potrebbe omettere una richiesta prima di pubblicarla.
Attacchi alle funzioni hash	Funzioni hash resistenti a collisioni e seconde preimmagini. Hash chain collega ogni entry alla precedente.	La sicurezza dipende dalla resistenza a collisioni della funzione hash usata.
Dispositivo compromesso	Firme e cifratura proteggono i messaggi dopo la generazione. Ricevuta per verificare l'inclusione.	Un malware può alterare il voto prima della cifratura, rubare credenziali o chiavi. Fuori dalle garanzie del protocollo.
Coercizione e vote buying	La ricevuta non mostra il voto in chiaro. Sostituzione successiva prima della chiusura.	La coercizione non è eliminata se l'elettore collabora o mostra informazioni locali.
Denial of Service	Rate limiting, logging, blocco temporaneo, ridondanza del servizio.	Il DoS resta un problema infrastrutturale.

Limiti residui e compromessi non completamente risolti

La soluzione raggiunge un compromesso ragionevole tra segretezza, integrità e controllo pubblico, ma non elimina tutte le criticità del voto elettronico.

Verificabilità universale solo parziale

Il pubblico può verificare il registro, le firme, le versioni, l'unicità delle schede finali e la coerenza numerica del risultato. Tuttavia, non può verificare autonomamente che ogni ciphertext sia stato decifrato nel voto in chiaro corretto. Questa è una scelta consapevole: pubblicare informazioni troppo dettagliate potrebbe rafforzare la possibilità di dimostrare a terzi il proprio voto. Una verificabilità universale completa richiederebbe tecniche crittografiche ulteriori, come prove di corretta decifratura, non incluse nel nucleo base.

Dipendenza dalla separazione tra RA, BB e TA

Se RA, BB e TA colludono, oppure se vengono combinati log e metadati, lo pseudoanonimato viene compromesso. Per questo motivo, il protocollo richiede una chiara separazione organizzativa e tecnica tra le entità e una minimizzazione dei log non necessari.

Limiti del Bulletin Board

La hash chain protegge contro modifiche successive alla pubblicazione, ma non impedisce al BB di non pubblicare una richiesta ricevuta. La ricevuta firmata è quindi essenziale: se l'elettore non riceve una ricevuta valida, non può considerare il voto correttamente registrato. Il BB deve rimanere disponibile e pubblicamente consultabile.

Custodia della chiave di scrutinio tramite Shamir

L'uso di Shamir rafforza la custodia della chiave di scrutinio, perché meno di t commissari non possono ricostruire K_{wrap} . Tuttavia, se almeno t commissari colludono, possono ricostruirla. Inoltre, il protocollo non implementa una vera decifratura a soglia: durante lo scrutinio la chiave completa sk_{TA_dec} viene recuperata temporaneamente nell'ambiente della TA.

Resistenza alla coercizione non piena

La ricevuta non contiene il voto in chiaro e la sostituzione del voto riduce il valore di una prova ottenuta prima della chiusura. Tuttavia, un elettore potrebbe comunque collaborare con il coercitore mostrando informazioni locali.

Autenticazione basata su password

L'uso di salt e hash evita la memorizzazione di password in chiaro e contrasta tabelle precalcolate, ma non elimina il rischio di password deboli, phishing o compromissione del database. Un secondo fattore o certificati personali sono considerati estensioni.

Token non blindato

La RA conosce il collegamento tra identità reale e pseudonimo p_i al momento dell'emissione dell'autorizzazione. L'adozione di blind signature richiederebbe un protocollo di firma cieca correttamente progettato e analizzato, con padding e controlli adeguati. Poiché tale costruzione non è inclusa nel nucleo base del progetto, si sceglie di non adottarla e di dichiarare esplicitamente il rischio residuo di collegabilità presso la RA.

Radice di fiducia iniziale

L'autenticità delle chiavi pubbliche si basa sulla pubblicazione sul portale istituzionale autenticato dell'Ordine. La compromissione del portale consentirebbe la sostituzione delle chiavi pubbliche. Questa assunzione non è risolvibile dal solo protocollo crittografico.

Dispositivo dell'elettore compromesso

Il protocollo protegge i messaggi dopo la generazione, ma non può garantire che il dispositivo mostri correttamente la scelta o che non alteri il voto prima della cifratura. Un malware può rubare credenziali, t_i , sk_i^{vote} o casualità. Questa minaccia resta fuori dalle garanzie principali del protocollo. La disponibilità delle funzioni di sostituzione dipende inoltre dalla conservazione dello stato pseudonimo locale. La sua perdita impedisce nuove versioni del voto, senza annullare quelle già registrate.

Disponibilità del sistema

Il protocollo crittografico non risolve attacchi DoS, guasti di rete o indisponibilità dei server. Questi problemi devono essere gestiti con misure infrastrutturali.

Considerazioni per WP4

Funzionalità da implementare

Il prototipo dovrà includere:

1. generazione dei parametri dell'elezione;
2. generazione delle chiavi di RA, BB e TA;
3. serializzazione e cifratura di sk_{TA_dec} tramite K_{wrap} ;
4. generazione delle quote Shamir di K_{wrap} ;
5. ricostruzione di K_{wrap} solo con almeno t quote valide;
6. autenticazione simulata degli elettori presso la RA;
7. emissione di una sola autorizzazione pseudonima per ciascun elettore;
8. generazione di t_i , calcolo di $p_i = H(t_i)$ e della coppia pseudonima dell'elettore;

9. memorizzazione persistente e protetta dello stato pseudonimo dell'elettore e relativo recupero dopo la riapertura dell'applicazione;
10. cifratura probabilistica del voto;
11. firma pseudonima del pacchetto di voto;
12. validazione del pacchetto da parte del BB;
13. registrazione append-only con hash chain;
14. emissione della ricevuta firmata;
15. sostituzione del voto prima della chiusura;
16. chiusura dell'urna;
17. selezione dell'ultima versione valida per ogni p_i ;
18. recupero temporaneo di sk_{TA_dec} tramite K_{wrap} ;
19. scrutinio finale;
20. firma del risultato da parte della TA;
21. verifica individuale della ricevuta;
22. controllo pubblico della hash chain e della coerenza numerica del risultato.

Test di sicurezza da eseguire

Autenticazione e autorizzazione. Accesso con credenziali corrette; rifiuto di credenziali errate; rifiuto della seconda richiesta di autorizzazione per lo stesso elettore; invalidità dell'autorizzazione se vengono modificati p_i , pk_i^{vote} o $election_id$.

Firme digitali. Accettazione di una firma valida; rifiuto se il messaggio viene modificato; rifiuto se la firma viene modificata; rifiuto se viene usata la chiave pubblica sbagliata.

Cifratura del voto. Corretta decifratura di un voto valido; cifrature diverse dello stesso voto grazie alla casualità; rifiuto o classificazione come anomalo di un plaintext non appartenente all'insieme delle liste valide.

Shamir Secret Sharing e custodia della chiave. Corretta ricostruzione di K_{wrap} con almeno t quote valide provenienti da commissari autorizzati con indici distinti; fallimento della ricostruzione o impossibilità di aprire $blob_{TA}$ con meno di t quote; se una quota viene alterata, la ricostruzione produce una K_{wrap} errata e l'apertura autenticata di $blob_{TA}$ fallisce (verifica del MAC); impossibilità di avviare lo scrutinio prima dell'evento CLOSE; recupero temporaneo di sk_{TA_dec} solo dopo ricostruzione corretta di K_{wrap} e apertura valida del blob.

Bulletin Board. Inserimento corretto di un voto valido; aggiornamento corretto della hash chain; rilevazione di alterazioni di una entry; rilevazione di cancellazioni o riordinamenti; verifica della ricevuta firmata dal BB.

Replay e sostituzione. Mancato conteggio doppio di un pacchetto identico; accettazione di una sostituzione con versione consecutiva; rifiuto di una sostituzione con versione non valida; conteggio solo dell'ultima versione valida prima di CLOSE; rifiuto di una sostituzione che supera $V_{\max}$; rifiuto di voti o sostituzioni dopo CLOSE.

Persistenza e recupero dello stato pseudonimo. Chiusura e successiva riapertura dell'applicazione senza perdita dello stato pseudonimo dell'elettore; riapertura dello stato locale senza necessità di interagire nuovamente con la RA; recupero dei medesimi t_i , p_i , τ_i , pk_i^{vote} , sk_i^{vote} , della versione corrente e delle ricevute già ottenute; corretta sostituzione del voto dopo la riapertura dell'applicazione; impossibilità di produrre una nuova versione se lo stato locale è assente, alterato o non recuperabile; permanenza della validità dell'ultima scheda già registrata anche in caso di perdita definitiva dello stato locale.

Scrutinio. Avvio dello scrutinio solo dopo la chiusura; avvio solo dopo ricostruzione valida di K_{wrap} ; decifratura delle sole schede finali; calcolo corretto dei totali; firma del risultato finale; verifica della relazione:

$$\sum_j N_j + N_{anomale} = N_{entry_finali}$$

Verifica individuale e pubblica. Verifica della ricevuta da parte dell'elettore; controllo dell'inclusione della scheda nel BB; verifica pubblica dell'intera hash chain; verifica della firma della TA sul risultato; controllo della coerenza numerica del tally.

Verificabilità pubblica delle firme e degli identificativi. Verifica pubblica di τ_i con pk_{RA} per ogni entry, confermando che l'autorizzazione è autentica; verifica pubblica di σ_i con pk_i^{vote} per ogni entry, confermando che il pacchetto è stato firmato dal titolare della coppia pseudonima; ricalcolo pubblico di RID_i a partire dai campi dell'entry e confronto con il valore pubblicato; verifica che per ogni p_i esista una sola scheda finale conteggiabile.

Componenti escluse dal prototipo base

Per mantenere il WP4 implementabile, non è necessario realizzare nel prototipo base: Merkle tree sull'elenco degli aventi diritto; mirror indipendenti del Bulletin Board; checkpoint periodici distribuiti; vera decifratura a soglia; cancellazione sicura della memoria; prove crittografiche pubbliche di corretta decifratura; autenticazione forte con certificati personali X.509; mitigazioni infrastrutturali complete contro DoS.

Metriche di prestazione

Nel WP4 dovranno essere misurate almeno: tempo di emissione dell'autorizzazione RA; tempo di cifratura del voto; tempo di firma del pacchetto; tempo di verifica da parte del BB; tempo di aggiornamento della hash chain; tempo di verifica della ricevuta; tempo di generazione delle quote Shamir; tempo di ricostruzione di K_{wrap} ; tempo di apertura del $blob_{TA}$; tempo di scrutinio; tempo di verifica pubblica del registro; dimensione del pacchetto di voto; dimensione della ricevuta; crescita del tempo di verifica al crescere del numero di eventi.